

Network Security Threat Intelligence Modeling Based on Knowledge Graph

1st Yibo Yang*

Network Security Department. YNCERT/CC
Kunming, of Yunnan, China
yangyibo@cert.org.cn

2nd Yuankang Zhao

Kunming, of Yunnan, China
1756972525@qq.com

Abstract—Knowledge graph, as a form of efficient organization of entities and concepts, can organize scattered distributed data and provide support for data analysis and knowledge reasoning for threat modeling of cyber security. In this paper, based on ATT&CK threat intelligence, we use knowledge graph modeling technology to study the construction of a threat intelligence visualization model for cyber security attacks.

Keywords—cyber security; knowledge graph; threat modeling; intelligence reasoning

I. INTRODUCTION

A. Background and Purpose

Information networks face daily threats from malicious software and attackers. To combat these threats, defenders must leverage Cyber Threat Intelligence (CTI) and develop robust defense systems. CTI has emerged as a critical tool in enhancing cybersecurity. MITRE's ATT&CK framework provides a structured and comprehensive description of cyberattacks, serving as a vital resource for security professionals.

B. Research Status

Internationally, CTI research has advanced significantly, focusing on multi-source data integration, automated threat analysis, and real-time intelligence. In China, while research in CTI and knowledge graphs is growing, challenges remain in terms of systematic approaches, data scale, and automation.^[2]

C. Existing Challenges

Data Integration: Difficulty in merging heterogeneous data sources. **Threat Modeling:** Limited accuracy and adaptability to evolving threats. **Visualization:** Static models lack interactivity, slowing decision-making. **Research Focus and Significance**^[1]

This paper aims to develop a visualization model integrating ATT&CK and knowledge graphs to enhance data integration, threat modeling, and interactive analysis. It seeks to address current gaps and improve the efficiency of cybersecurity defenses, advancing the field toward cognitive intelligence.

II. KEY TECHNOLOGIES

A. Threat Modeling

Threat modeling is an important part of cybersecurity threat analysis, a structured approach to analyzing and solving security problems, used to identify, quantify, and respond to threats, using abstraction to help think about risk. The process of communicating the destructive power of a security breach, defining countermeasures to prevent and mitigate system threats, and prioritizing the effective

implementation of remedial measures by security personnel. As in the dimension of business security, the process of improving system security by locating attack targets and exploitable business security vulnerabilities, and then defining countermeasures to prevent or mitigate system business risks. Threat modeling mainly contains several main elements of Assets, Threats (Attack Behavior), and Vulnerabilities, and ensures the three elements of information CIA (Confidentiality / Integrity / Availability) by identifying threats and formulating protection strategies.^[2] Threats can lead to Exposure by exploiting the system's Vulnerabilities, resulting in Risk. the appropriate response is to use Safeguards to mitigate the risk so that the Assets are secured, The threat model is shown in Figure 1.

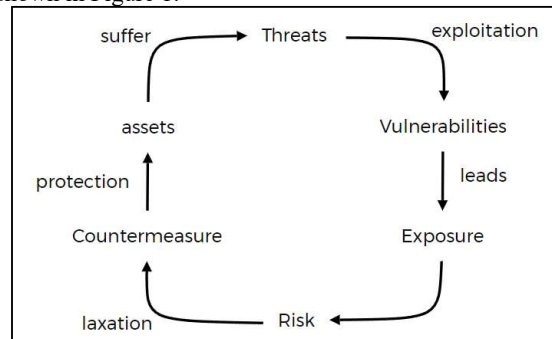


Figure 1. Threat modeling target map

B. STIX 2.0 and ATT&CK

STIX (Exchange Cyber Threat Intelligence) is a description language and information organization structure for threat intelligence in cyberspace. STIX 2.0 gives a semantic structure paradigm for describing threat intelligence information and knowledge.^[4]

MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) is a framework for analyzing and organizing knowledge of attack techniques from an attacker's perspective. It identifies cyberattack behaviors and assesses the coverage of attack and defense capabilities across the entire attack life cycle. Originally focused on intranet and Windows-based attacks, ATT&CK has expanded to include multi-scenario, multi-platform, and multi-source data analysis, covering environments like mobile, industrial control, and cloud. Security vendors use the ATT&CK model to assess product capabilities in threat identification, and open-source projects like CALDERA and Atomic Red Team leverage ATT&CK for automated red and blue team simulations. Many security products, such as EDR, IDS, and Dynamic Sandboxes, map their threat detection capabilities to the ATT&CK framework for more effective threat modeling. The correlation between

the ATT&CK and the STIX structure is shown in Figure 2. [5]

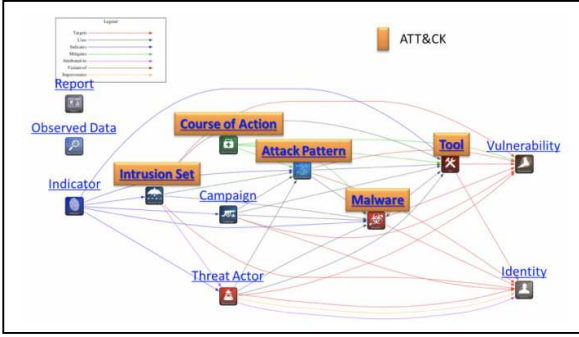


Figure 2. Mapping of ATT&CK to the Threat Intelligence Exchange STIX

C. Knowledge Graph

Knowledge graphs are structured semantic knowledge bases describing concepts, entities, and relationships in the real world, essentially a semantic network. Knowledge graphs are generally represented in two forms: triples and graph-based structures. The ternary $G = (E, R, S)$ is a generic representation of a knowledge graph, where $E = \{e_1, e_2, \dots, e_n\}$ denotes the set of entities in the knowledge graph containing a total of $|E|$ kinds of different entities, $R = \{r_1, r_2, \dots, r_n\}$ denotes the set of relations in the knowledge graph containing a total of $|R|$ kinds of different relations, and $S \subseteq E \times R \times E$ denotes the knowledge graph in the set of triples. The knowledge graph represented by the triad contains two forms of knowledge: $G_{xy} = (\text{entity } x, \text{relation } r, \text{entity } y)$ denotes that the entity x has a certain relation with the entity y , $G_{xp} = (\text{entity } x, \text{attribute } p, \text{attribute value } v)$ denotes that entity x has some attribute p whose attribute value is v . The graph-based knowledge graph is denoted as $G = (V, E)$ where the set of nodes V denotes all the entities and attributes, and the set of edges E denotes the relationships between entities and entities, and entities and attributes. [11] As a specialized knowledge graph in the field of security, security knowledge graph fully integrates security knowledge, experience and data, and gives full play to the great potential value of artificial intelligence technology. The cybersecurity knowledge graph ontology covers "tactics - technologies - tools - data sources - malware - attack patterns - weaknesses - vulnerabilities - hardware and software" corresponding to cyber threats, and so on. The ontology of cyber security knowledge graph covers the complex, multi-dimensional and multi-path interactions of cyber threats. [8]

The research direction of this paper is the threat modeling of security knowledge graph, i.e., modeling the attack behaviors of each attack lifecycle based on ATT&CK for the domain knowledge of knowledge base and intelligence base in the field of cyber space security, in order to give the security ontology paradigm that is normalized, abstracted, and reasonable. The ontology consists of entity (node) types, attribute types of entities and relationship types between entities, i.e., abstract conceptual structure classes that represent the graph structure. The ontology paradigm determines the scope of knowledge/intelligence covered by the knowledge graph,

the granularity of data abstraction, and the template of semantic associations, which in turn determines the usability, coverage, and value of use of relevant reasoning applications around the knowledge graph.

D. Threat Modeling by Combining Knowledge Graphs with the MITRE ATT&CK Framework

The MITRE ATT&CK framework provides a structured description of cyberattack behaviors and is an important tool for threat intelligence modeling. By integrating knowledge graphs with the ATT&CK framework, more flexible and dynamic threat modeling can be achieved. For example, knowledge graphs can represent how attackers use certain techniques, tools, and targets, as well as their evolving relationships, helping security personnel quickly identify attack patterns, attack paths, and potential threats. The key technical processes for threat modeling by combining the ATT&CK framework with knowledge graphs include: data collection and mapping, knowledge graph construction and enhancement, and threat modeling and analysis.

III. DESIGN AND IMPLEMENTATION

A. Construction Methods

The process of building a graph involves extracting entities (nodes) and relationships (edges) from unstructured data and representing them as graph structures.

1) *Entity Extraction*: Entities are nodes in the knowledge graph that represent concepts, objects, people, etc. in the real world. The purpose of entity extraction is to recognize meaningful noun phrases in the text and use them as nodes. Given a text T , find the set of entities:

$$E = \{e_1, e_2, \dots, e_n\} \quad (1)$$

2) *Relation Extraction*: Relationships are edges that connect entities and represent associations or interactions between entities. The goal of relationship extraction is to recognize semantic relationships between entities in a text. Formula: Given a set of entities E and a text T , find the set of relations:

$$R = \{r_1, r_2, \dots, r_n\} \quad (2)$$

where each relation r_i is a triple (e_i, p_i, e_j) , representing the relation r_i between the entity e_i and the entity e_j .

3) *Knowledge Graph Construction*: The extracted entities and relationships are organized into a directed graph where nodes represent entities and edges represent relationships. where V is the set of nodes (entities); E is the set of edges (relations), each edge connects two nodes and is labeled with a relation. Formula:

$$K = (V, E) \quad (3)$$

Construction steps: for each relation triad (e_i, p_i, e_j) , add nodes e_i and e_j to the graph and add an edge pointing from e_i to e_j labeled with relation p_i .

4) *Inference and Update*: Knowledge graphs can be extended and updated through inference, which is the derivation of new knowledge from existing knowledge.

Formula: If $(\epsilon_1, \rho_1, \epsilon_2)$ and $(\epsilon_2, \rho_2, \epsilon_3)$ are edges in a knowledge graph, one can deduce $(\epsilon_1, \rho_3, \epsilon_3)$, where ρ_3 is the combination of a combinatorial relationship between ϵ_1 and ϵ_3 .

5) *Representation and storage of maps*: The final knowledge graph needs to be stored and queried. Common forms of storage include graph databases (e.g., Neo4j) formulas: In graph databases, a graph G is usually represented as:

$$G = (N, E, L) \quad (4)$$

where N is the set of nodes; E is the set of edges; and L is the set of labels for nodes and edges.

The core formulas for constructing knowledge graphs involve entity extraction, relationship extraction and representation of graph structures. These formulas and steps are implemented through techniques such as machine learning, natural language processing, and graph theory, which ultimately form a structured graph that can represent the knowledge of cybersecurity attack threats. In this paper, we use reuse existing cybersecurity ontologies for construction, whose entities and relationships have been extracted and defined in the ATT&CK model data.

Firstly, the threat intelligence data in ATT&CK and the cyber security threat intelligence organization structure model STIX2.0 are combined. The threat modeling in this paper mainly includes six main entity elements such as technologies, tactics, software, groups, mitigations and datasources. Based on the structural definition of the attack process in the attack threat intelligence structural model^[8], the relationship between the above entities can be described as follows: groups use specific software and utilize specific techniques to launch attacks; software provides attack tools for techniques; specific attacks can be blocked by executing specific mitigations; techniques can be blocked by executing specific mitigations; techniques can be blocked by executing specific mitigations; techniques can be blocked by executing specific mitigations. techniques; techniques can be combined into specific tactics; datasources provide models or examples for techniques. The relationship of each entity element in the attack threat model is shown in Figure 3.

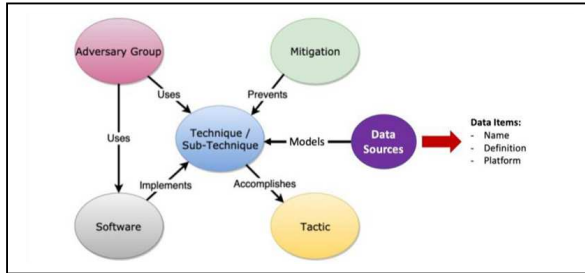


Figure 3. Threat Intelligence Entity Relationship Map of ATT&CK

Secondly, the latest threat intelligence datasheet is obtained from the official website of ATT&CK (<https://attack.mitre.org/>), which lists all the concepts in the domain and a detailed explanation of the concept, and for each concept, lists all its possible attributes and the attribute values corresponding to the attributes, the

datasheet contains information on the attribute values of technologies, tactics, software, groups, campaigns, mitigations, relationships, datasources, and citations. The graph-based knowledge graph is denoted as $G = (V, E)$ where the set of nodes V denotes all entities and attributes, and the set of edges E denotes the relationships between entities and entities, and entities and attributes. According to the above definition and division of the ontology, two types of node sets V and E are formed, set $V = \{v1, v2, \dots, v9\}$, and each entity V contains a number of attribute values, take the entity group as an example, the definition of entity "group" is shown in Table I.

TABLE I. DEFINITION TABLE FOR THE "GROUP" ATTRIBUTE

Attribute Information Sheet for Group	
attribute name	attribute description
id	Define organization ID
Stix id	Define ids that are managed with STIX
name	Attack organization name
description	Describe the attack organization, including the attack characteristics and scope
url	Page information at attack.mitre.org
created	First creation time
last modified	Last modification time
domain	Domain classification
version	version information
contributors	Discoverer information
associated groups	Associated organization information
associated groups citations	associated groups citations information
relationship citations	relationship citations information

Finally, the entity relationship information is defined, and the set E contains the relationships between entities and entities, entities and attributes, which are mainly represented as the set of entity relationship pairs $(v1, R, v2)$, where the set of relationship categories $R = \{r1, r2, r3, r4\}$, corresponds to the relationships: attributed-to/detects/mitigates/uses. The set of relationship sets is shown in Table II.

TABLE II. TABLE OF INTER-ENTITY RELATIONSHIP DEFINITIONS

Entity Relationship Correspondence Table		
source entity	relationship	target entity
campaign	attributed-to	group
datasources	detects	technique
mitigation	mitigates	technique
campaign	uses	software
group	uses	software
software	uses	technique

B. Building Tools and Processes:

In the field, technicians can understand the ontology model as the ER model of relational database (Entity-relationship model), and there are open source visualization tools for ontology construction using Neo4j^[15]. The above tools are usually applied in the construction stage of the ontology schema, and a large number of instances of Individuals need to be populated in

the later stage to supplement the entire knowledge graph. A front-end web interface is built using the Django library for Python, through which users can upload .xlsx files to a specified directory. The uploaded files are stored in a temporary directory for subsequent processing. In the data processing stage, the system parses the uploaded .xlsx file and splits the data into multiple CSV files. During the splitting process, the system will process each worksheet one by one and process the data containing merged cells and those not containing merged cells separately. For the data that does not contain merged cells, it is directly read and converted to CSV files. For data that contains merged cells, it will be converted to CSV file by traversing each cell, parsing and recovering the values of the merged cells, and then converting them to CSV file. After the split is complete, the system connects to the Neo4j graph database and clears the existing graph data. This step is to ensure that the database is empty before the new data is imported to avoid data conflicts and redundancy. Next, the system reads the generated CSV files one by one according to a predefined logic and imports the data into the Neo4j graph database. Different types of data tables will use different processing functions. For the nine entities in ATT&CK corresponding to the attribute information tables call their respective functions for data writing these functions will perform specific processing and storage operations according to the different characteristics of the data. Through the management and control of the Django framework to ensure the efficiency and reliability of the operation, so as to realize the efficient data management and visualization of the graph database. The process is shown in Figure 4

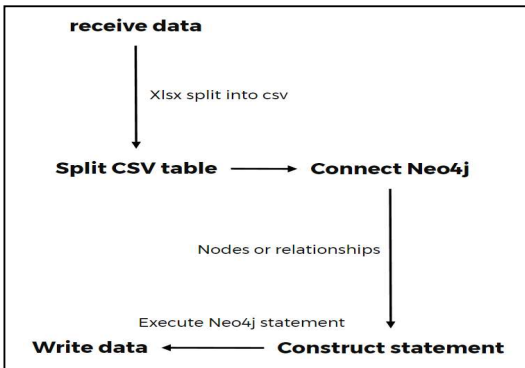


Figure 4. Entity Creation Flowchart

C. Finish building

A total of 5071 nodes were imported, while the Neo4j database backend nodes were established, including entity nodes, attributes and paths to relationships were established. The nodes are established as shown in Figure 5.

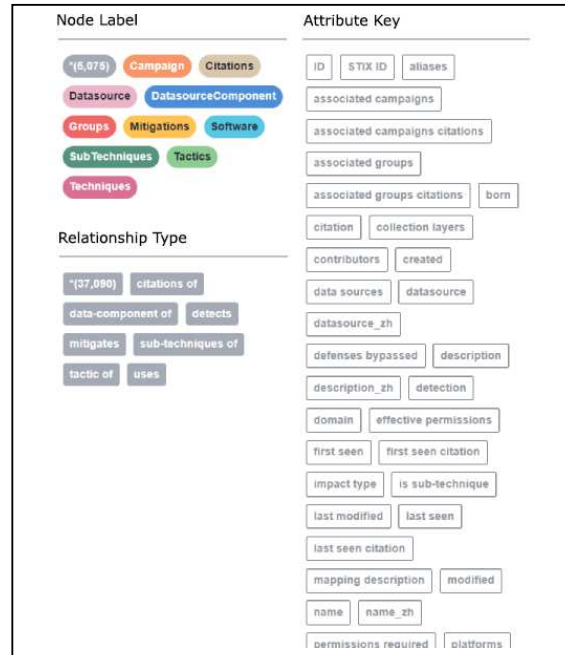


Figure 5. Entity, Attribute and Relationship Nodes

IV. PRESENTATION OF RESULTS

Based on the above implementation process the threat modeling of full ATT&CK is performed to form the attack threat knowledge graph as shown in Figure 6.

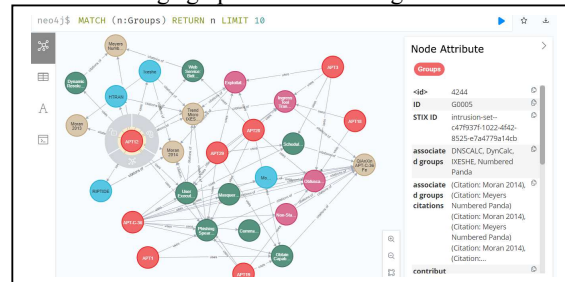


Figure 6. Attack Threat Knowledge Graph

Taking APT12^[9] in Group as an example, through graphical modeling, we can clearly see that the APT organization named APT12 mainly uses three software named HTRAN, RIPTIDE and Ixeshe to launch attacks, and utilizes five types of software named Dynamic Resolution: DNS Calculation, User Execution: Malicious File, Phishing: Spearphishing Attachment, Web Service: Bidirectional Communication and Exploitation for Client Execution. Execution: Malicious File, Phishing: Spearphishing Attachment, Web Service: Bidirectional Communication and Exploitation for Client Execution. Reports related to this group have appeared on Trend Micro IXESHE 2012, Moran 2014, Moran 2013, Meyers Numbered Panda, and several other cybersecurity-related media platforms.

APT12, APT29, APT-C-36 and APT28 all used the User Execution: Malicious File technique to carry out their attacks. APT3 and APT-C-36 are indirectly linked through the malware Imminent Monitor and the technique called

Obfuscated Files or Information, so that when the Imminent Monitor malware is detected during a security detection, the association can be reversed to check for the presence of the APT-C-36 attack technique and the Obfuscated Files or Information technique. 36 attack techniques and Obfuscated Files or Information techniques to further investigate and avoid network security risks. Through the neo4j statement^[15], you can query the relationship between two entities, such as APT12 and malware RIPTIDE relationship, the figure query can be obtained for the relationship "use" that is, APT12 and RIPTIDE there is a use relationship between. As shown in Figure 7 below.



Figure 7. Entity Relationship Inquiry Chart

V. CONCLUSION AND DISCUSSION

Network security big data brings opportunities and challenges to threat detection and analysis. We need more effective data collection, reasonable data organization, accurate data analysis and rich visualization capabilities to support the simulation, correlation, knowledge precipitation and other processes in the analysis task, and then gradually automate security defense capabilities. With the accumulation of ATT&CK's behavioral knowledge and the increasing improvement of related technologies, not only in the field of attack simulation and red-blue confrontation, but also in the field of detection and response, user entity behavioral analysis, threat hunting, antivirus, and other threat analysis products and solutions are gradually approaching the tactical-technical matrix and aligning. Using ATT&CK to model threats and build a knowledge base for behavioral analysis, and organizing it in the form of graphical data, can open up barriers between data and accelerate the fusion and analysis of multiple sources of data, such as threat intelligence, raw logs, detection data, scanning data, and threat knowledge base, etc. ATT&CK is more than just a model, a dictionary matrix, and a ruler, the ecosystem that ATT&CK facilitates will promote data interaction and sharing between organizations and their internal and external data under the ecosystem.^[13] data interaction and sharing within and outside the organization. In view of the complexity of the actual network environment, it is not enough to only model the attack behavior to analyze the problem. Based on this knowledge attack knowledge graph, it can be extended to design multiple ontologies to model and analyze the entire network threat, and is compatible with the MITRE organization's CAPEC, MAEC, and ATT&CK and other models of access and use, so as to achieve the multi-party threat intelligence to extract the key information and as the knowledge of the knowledge of the extension of the knowledge graph. Knowledge Graph.

The importance of artificial intelligence in the field of security attack and defense is becoming more and more prominent, and intelligence is becoming the core kinetic energy of network security defense. By applying security knowledge mapping to network attack and defense, it can realize attack modeling, path investigation, advance research and intelligent protection of network threats, effectively improve the ability of security threat detection, situation awareness, emergency response and tracking and tracing, and promote network security intelligence from perceptual intelligence to cognitive intelligence. Of course, research on key technologies of security knowledge mapping and application practices in attack and defense scenarios are still at an early stage, and further research and exploration are needed in theoretical methodology, standard formulation and talent cultivation, etc., in order to build a good technology ecology for attack and defense intelligence.

REFERENCES

- [1] Tounsi W, Rais H. A survey on cyber threat intelligence: Techniques, tools, and challenges [J]. *Computers & Security*, 2018, 72: 212–229.
- [2] Shostack A. *Threat Modeling: Designing for Security* [M]. Wiley, 2014.
- [3] The MITRE Corporation. MITRE ATT&CK®: Adversarial Tactics, Techniques, and Common Knowledge [EB/OL]. Available: <https://attack.mitre.org/>, 2023.
- [4] Barnum S. Standardizing Cyber Threat Intelligence Information with the Structured Threat Information eXpression (STIX) [J]. MITRE Corporation, 2012.
- [5] Jajodia S, Noel S, O'Berry B. Topological analysis of network attack vulnerability [J]. *Advances in Information Security*, 2005, 17: 247–266.
- [6] Red Canary. Atomic Red Team™: Open Source Security Testing [EB/OL]. Available: <https://redcanary.com/atomic-red-team/>, 2023.
- [7] Yin H, Song D, Chen S. *Automatic Malware Analysis* [M]. Springer, 2008.
- [8] Chen Y, Kao H, Lin C. Cybersecurity knowledge graph: A survey of knowledge representation techniques [J]. *Computers & Security*, 2022, 120: 102826.
- [9] Meyers A, Wardle P. *Numbered Panda: APT12 and the Secrets Behind Their Attacks* [R]. Trend Micro, 2014.
- [10] Moran N. *Exploiting the Supply Chain: Attack Techniques of APT12* [R]. FireEye Labs, 2013.
- [11] Song M, Xu W. An Efficient Graph-based Knowledge Representation Method for Cyber Threat Intelligence [C]. *International Conference on Security and Privacy in Communication Systems*, 2021: 342–353.
- [12] Chen P, Wang X. Advanced Persistent Threats: A Deep Dive into Attack Techniques [J]. *Cyber Defense Review*, 2020, 5(3): 45–63.
- [13] Tounsi W, Rais H. A survey on cyber threat intelligence: Techniques, tools, and challenges [J]. *Computers & Security*, 2018, 72: 212–229.
- [14] Miller K, Fernandez J. Knowledge Graph Construction for Cybersecurity Threats [C]. *IEEE International Conference on Big Data*, 2019: 3177–3184.
- [15] Katz D, Ganesan R. *Cybersecurity in Neo4j: Building Knowledge Graphs for Threat Detection* [M]. O'Reilly Media, 2021.